

NETWORK SECURITY

Mg. Ing. CIP Adolfo Cáceres Luque



Universidad
Tecnológica
del Perú

Introducción al Network Security

Unidad 2 – Semana 3



Universidad
Tecnológica
del Perú

Phishing alojado en página del gobierno peruano

Asunto: Su Tarjeta SuperClave Fue Deshabilitado (Activar Urgente)

Banco en Línea

ESTIMADO CLIENTE DE [REDACTED] SANTIAGO

Como parte de nuestras medidas de seguridad, examinamos periódicamente la actividad del sistema de **Banco [REDACTED] en línea**. Durante una reciente investigación, hemos observado un problema en su **Modulo de pago de facturas**.

Se recomienda restaurar el acceso a su servicio para obtener automáticamente los saldos de sus productos del portafolio financiero; y así poder seleccionar las opciones para realizar: Consultas, Pagos, Transferencias, Bloqueo y Activaciones, y Servicios Especiales.

Numero de identificacion de Caso: BP-Module-Billing-0000-2854-4843



Para resolver este problema puede entrar a su cuenta desde el siguiente enlace de código auto generado para el problema de su caso. Con esto podrá acceder a los módulos de servicios de cuenta y completamente los servicios contratados.

<http://www.bancomercantil.gob.pe/direccion/Home-Page/www.bancomercantil.gob.pe/>
Haga clic para seguir vínculo

Si eres cliente del [REDACTED] RECUERDA:
que puedes pagar tus cuentas

¡Clic para acceder a su Cuenta y Resolver el Problema. Gracias



<http://www.bancomercantil.gob.pe/direccion/Home-Page/www.bancomercantil.gob.pe/>

Banco en Línea

SERVICIO AL CLIENTE
VOX (800) 320 3000

PERSONAS **EMPRESAS**

Rut:
Clave:

9 2 5 0 1 -
8 7 4 3 6 k
Borrar
(Que es esto?)

Simula tu Crédito
Inversiones
Cotiza tu Hipotecario
Banca Propiedades
Descos. y Promociones

Últimos días, asegura tu auto y obtén hasta, \$150.000 desc. en bencina. [Leer más](#)

¡LLÉVATE 10.000 KMS. LANPASS!

EVITA FRAUDES electrónicos

Nuestros e-mails NO CONTIENEN LINKS hacia [Informate aquí](#)

Logro de la sesión



Al finalizar esta sesión, el estudiante, describe las características de funcionamiento de los protocolos AAA, así como las técnicas de Autenticación, Autorización, Contabilización utilizadas en los servidores Radius, TACACS y Kerberos.

Agenda

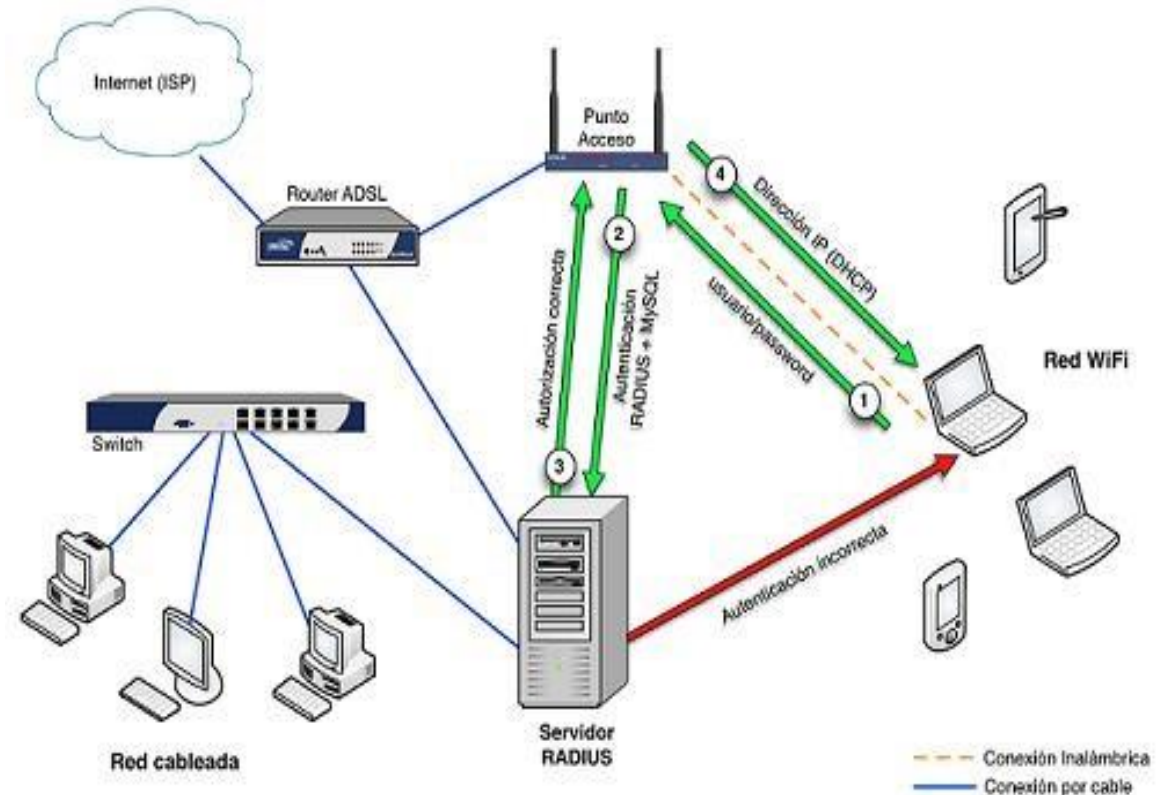
- Protocolos AAA
- Secure Network Management



Protocolo AAA (Authentication, Authorization, Accounting)

La familia de protocolos diseñados como mecanismo de control de acceso remoto a través de múltiples arquitecturas, brindando tres servicios en el que sus siglas así se mencionan

Autenticación, Autorización, Contabilización



Autenticación (Authentication)

Es el proceso por el que una entidad demuestra que es quien dice ser. ¿El usuario es quien dice ser?



Ejemplo:

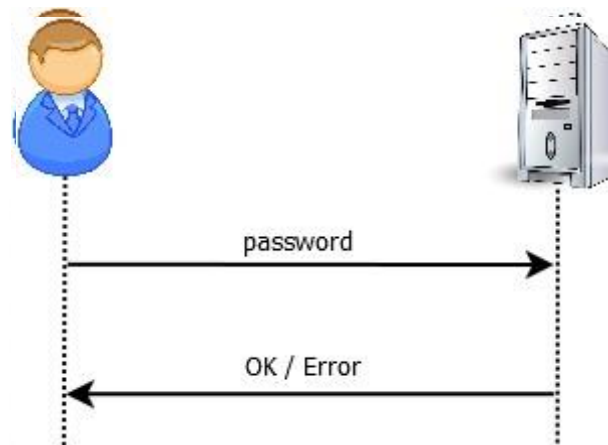
Algo que uno tiene (por ejemplo un **token**)

Algo que uno sabe (por ejemplo un **password**)

Algo que uno es (por ejemplo, una **huella dactilar**, **Face ID**)

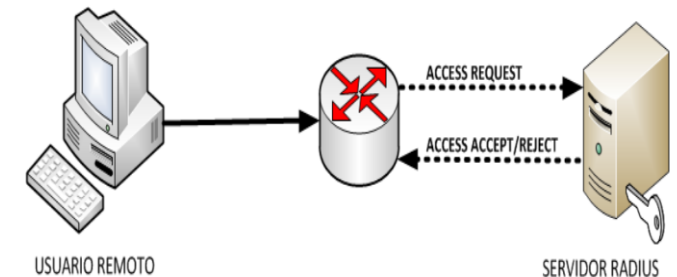
Proceso:

En general, una entidad es un **Cliente**, y la otra es un **Servidor** ante el cual se requiere **autenticación**



PROTOCOLO DE AUTENTICACIÓN

AUTENTICACIÓN AAA CON RADIUS



Autorización (**A**uthorization)

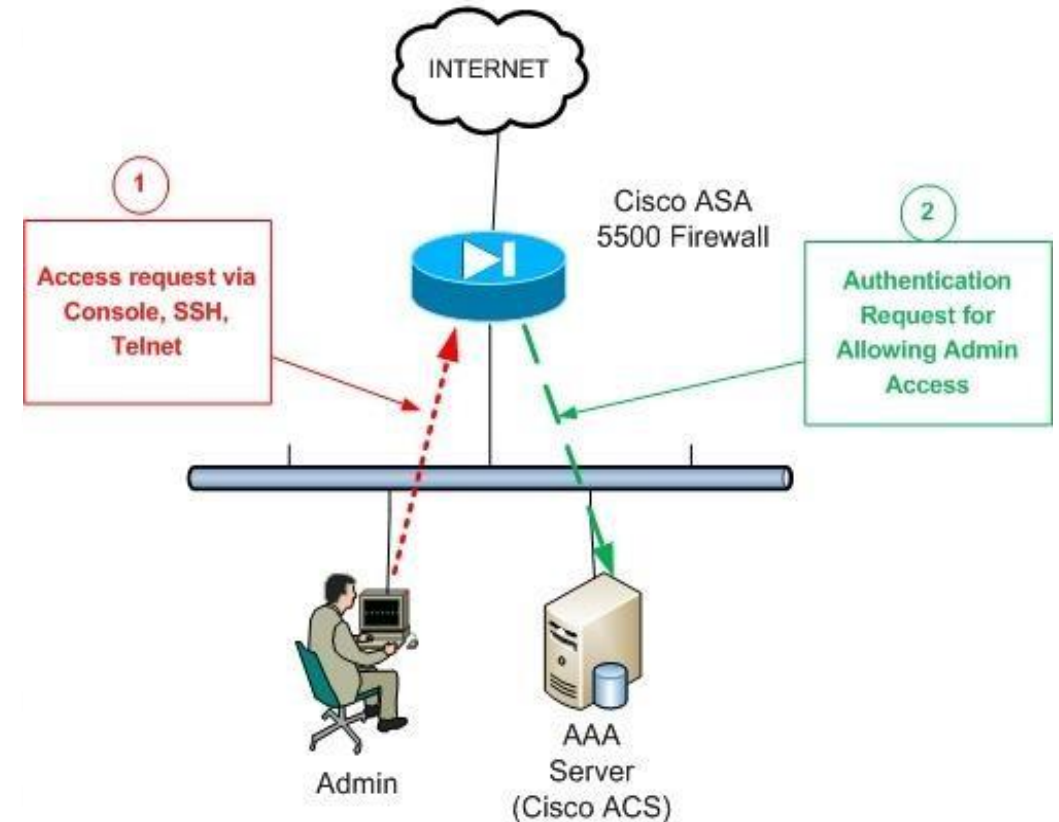
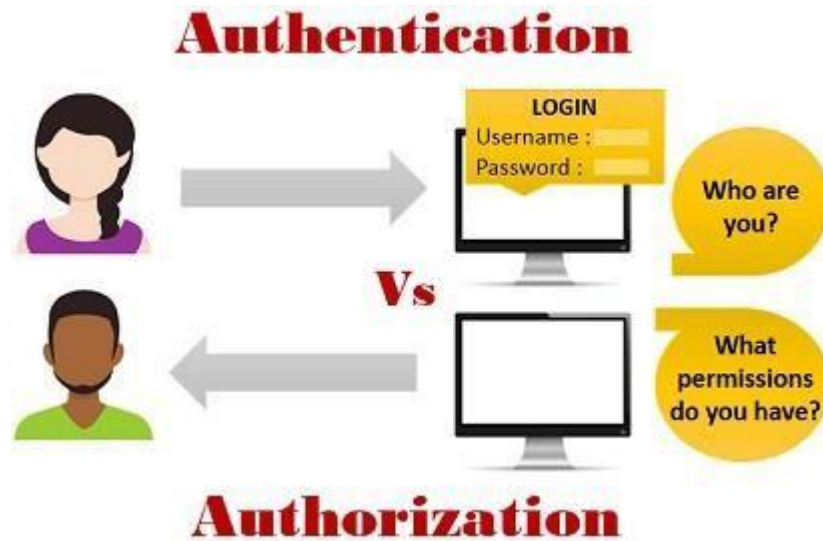
Dar privilegios específicos a una determinada Entidad, Proceso de control de acceso a la red. **¿Qué privilegios tiene el usuario autenticado?**

Proceso

La entidad pueda acceder a recursos basado en los privilegios específicos que el sistema provee.

Ejemplo:

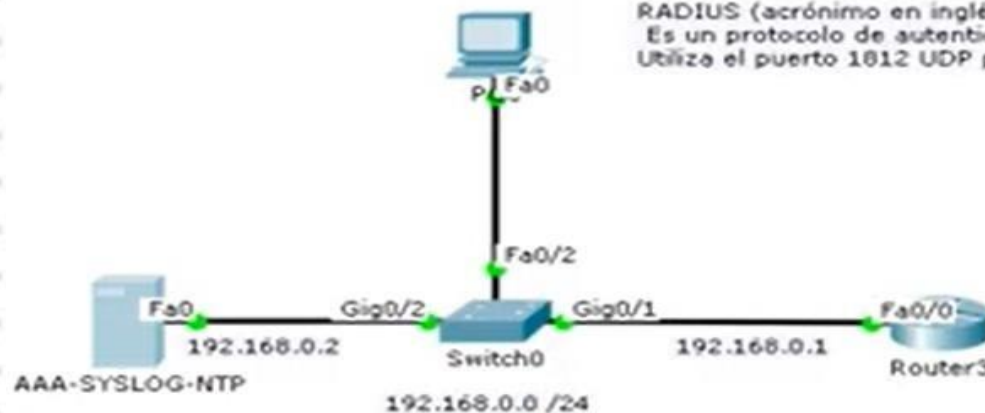
Privilegios de Edición
Privilegios de uso



Autorización (Authorization)

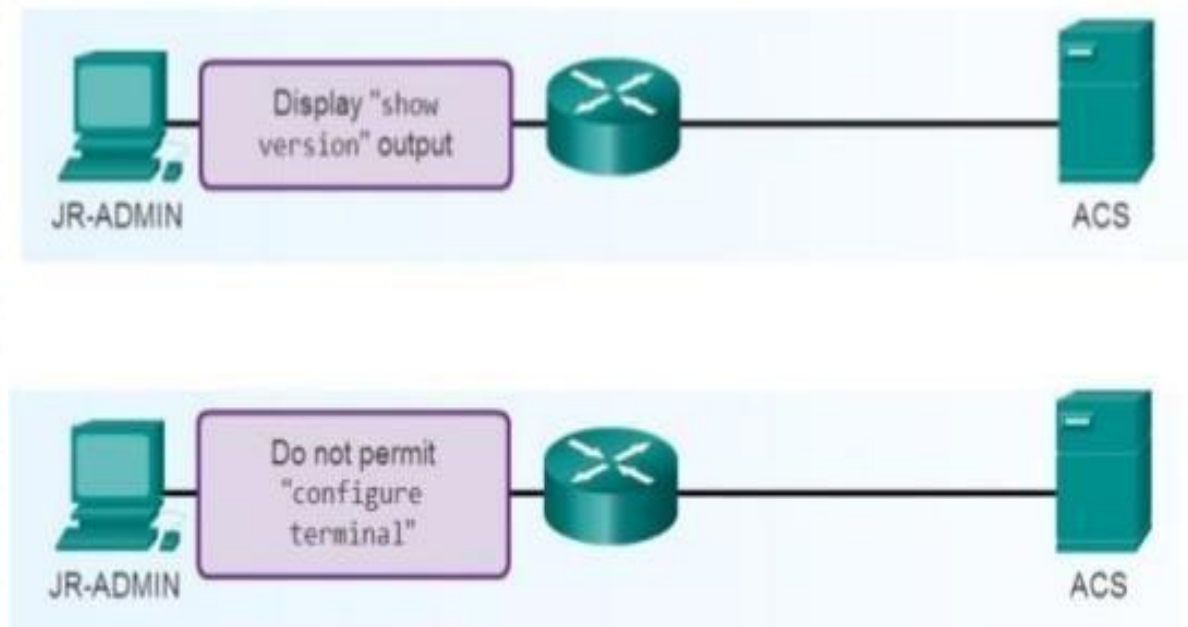
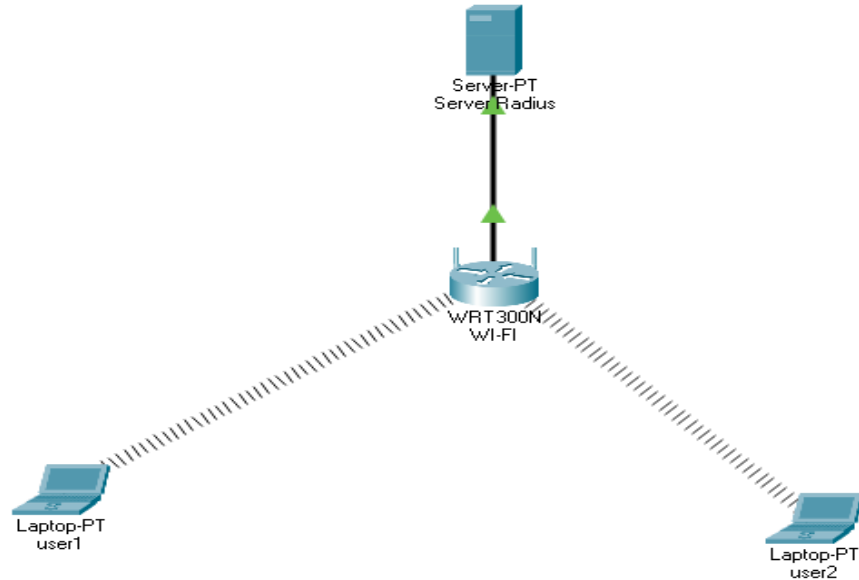
- En este proceso el usuario se autentica pudiendo el sistema de alguna forma validar que el mismo puede ingresar al equipo.
- Por ejemplo mediante un usuario y una contraseña o bien con un token.
- En nuestro caso el usuario y password para ingresar a un equipo. Solo que en este caso la base de datos de estos usuarios y contraseñas no están en el router.

AUTENTICACIÓN, ACCESO Y CONTABILIZACIÓN
AAA + SSH
PRUEBA DE REDUNDANCIA DE AUTENTICACION LOCAL Y REMOTA



Autorización (Authorization)

- Una vez que el usuario se ha autenticado este proceso permite definir los derechos de este usuario.
- En nuestro caso podemos darle acceso a un usuario solo para que pueda ver la configuración y no modificarla por ejemplo.

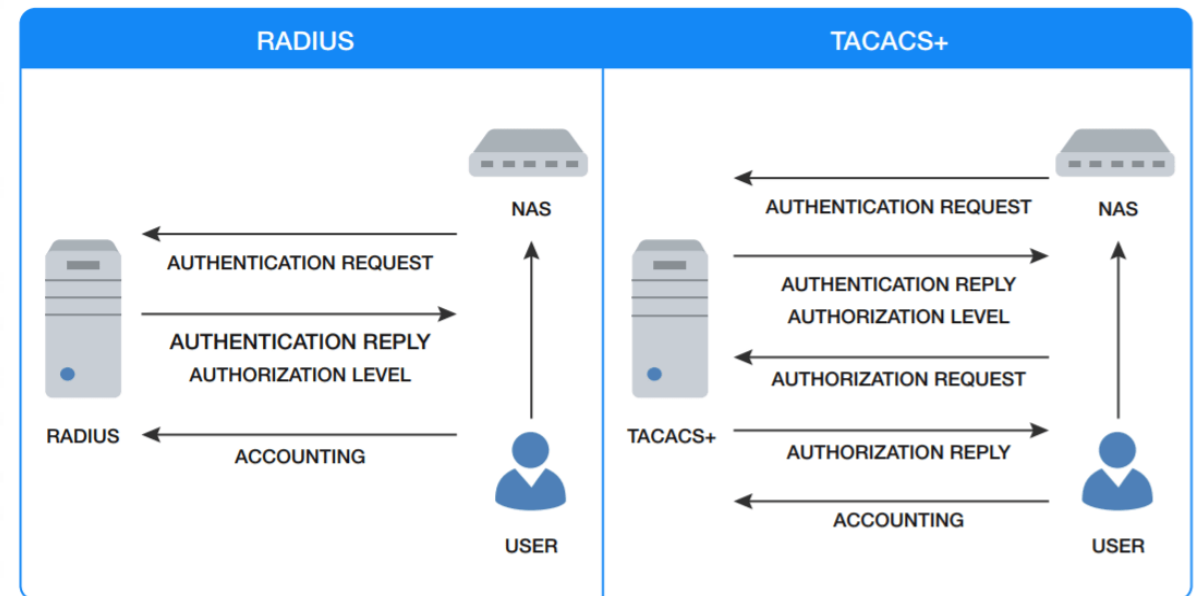
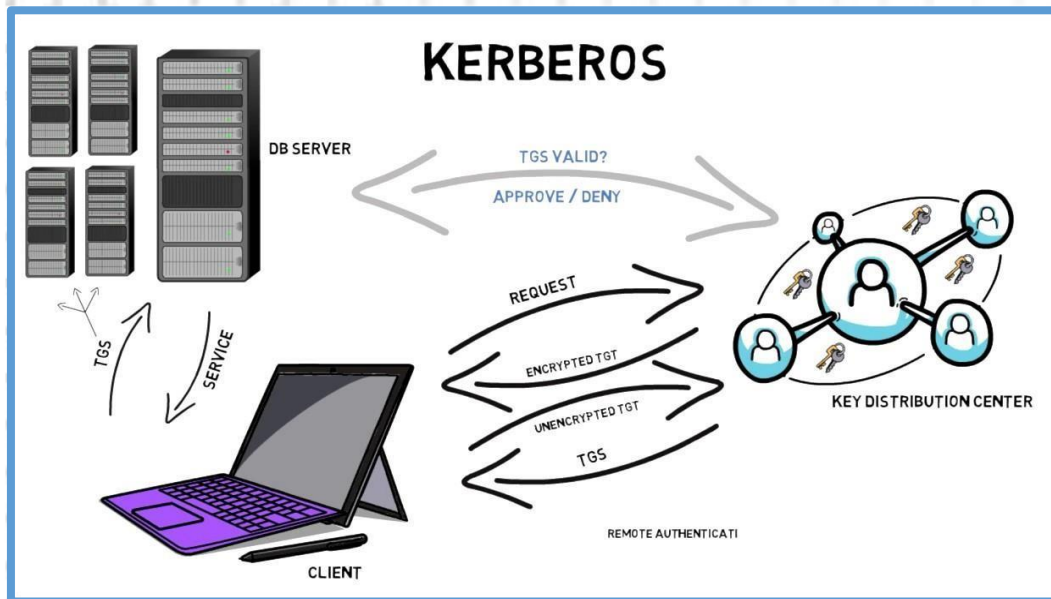




Ejemplos de Servidores

Radius
TACACS
Kerberos

Flujo de mensajes en un proceso de autenticación/autorización RADIUS

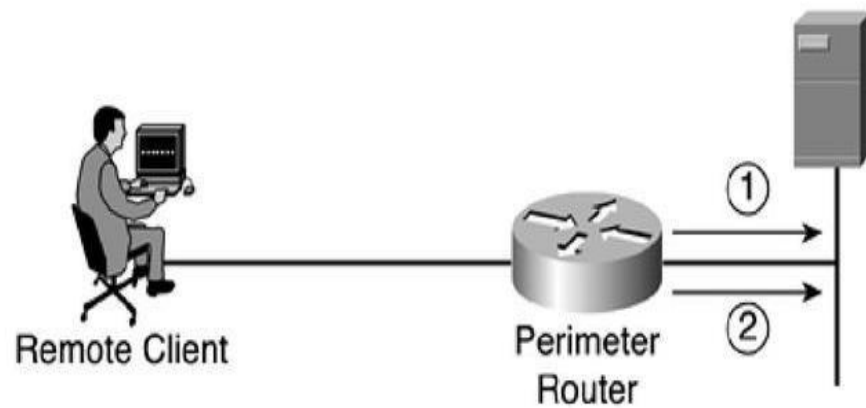


Contabilización (**A**ccounting)

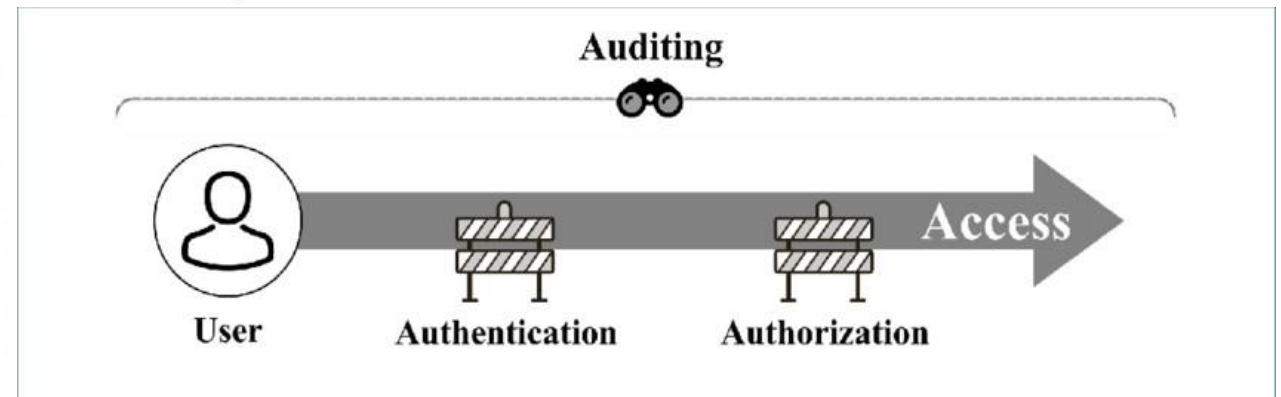
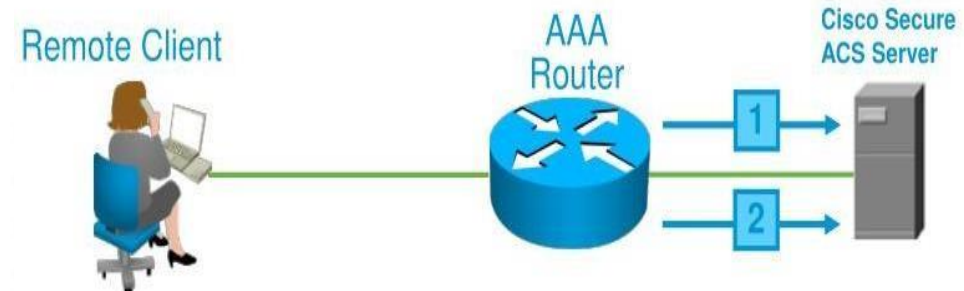
Proceso de registro de acciones llevadas a cabo por el usuario durante las sesiones establecidas

¿En que momento el usuario abrió la sesión y que hizo durante la misma?

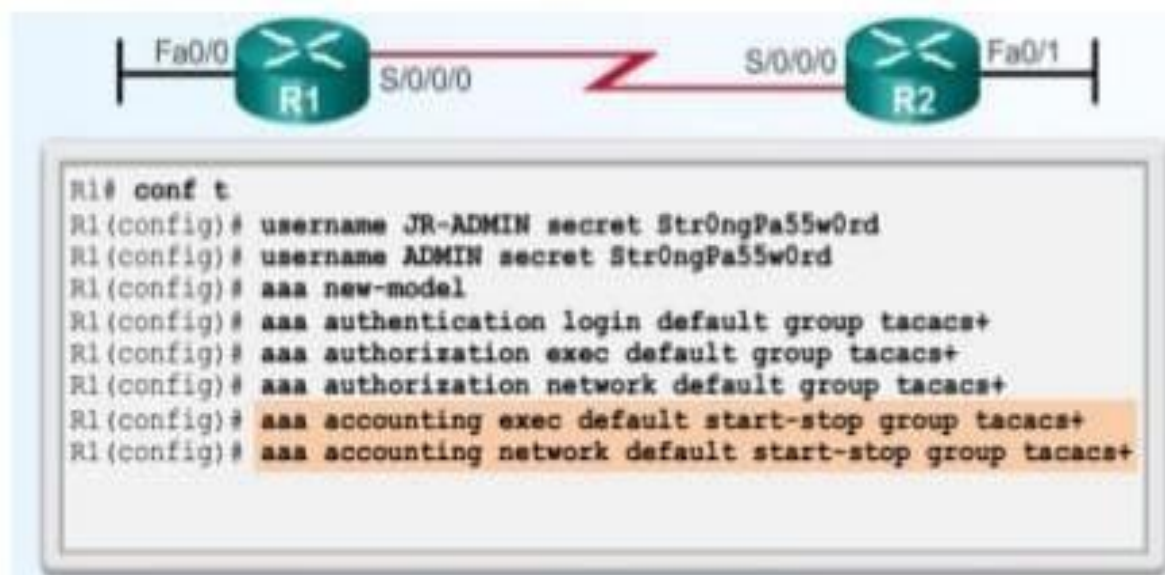
- Implementada usando una solución basada en un server AAA.
- Mantiene un registro detallado de lo que hace un usuario autenticado en un dispositivo.



1. When a user has been authenticated, the AAA accounting process generates a start message to begin the accounting process.
2. When the user finishes, a stop message is recorded ending the accounting process.



- Proceso que registra el acceso del usuario y detalles tales como fecha, hora, duración u otros, muy útil para auditorias.
- Accounting habilita el registro de actividad de un usuario.
- Útil para registrar actividades extrañas e inusuales.
- Para hacer troubleshooting de acuerdo a ultimas configuraciones realizadas.



router(config)#

```

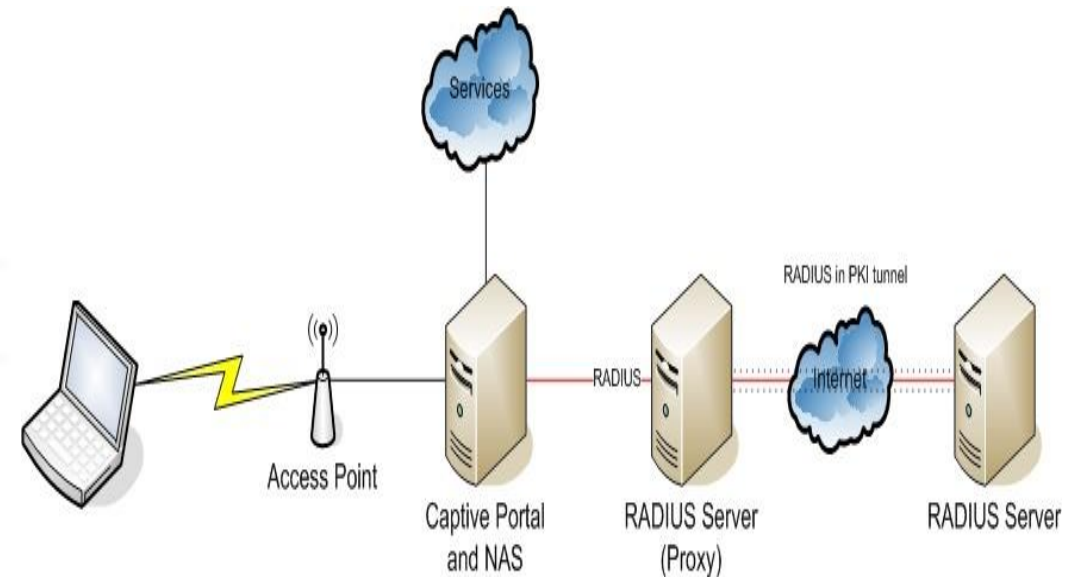
aaa account system wait-start local
aaa account network stop-only local
aaa account exec start-stop local
aaa acc command 15 wait-start local
  
```


Adicionalmente, una vez autenticado y autorizado, el cliente puede enviar una petición de contabilización para iniciar una sesión a la que el servidor RADIUS responderá, iniciándose un registro de conexión con datos sobre inicio/fin de sesión, volumen de datos transferidos, etc. La sesión finalizará con una petición por parte del servidor o del cliente (Accounting Stop).

Mensajes más comunes de RADIUS

Para controlar todas las fases del proceso de AAA, RADIUS dispone, entre otros, de los siguientes mensajes:

- **Access-Request.** Enviado por un cliente RADIUS para solicitar autenticación y autorización de acceso a red.
- **Access-Accept.** Enviado por el servidor RADIUS server en respuesta a un mensaje Access-Request. Este mensaje notifica al cliente su autenticación y autorización que corresponda aportando los atributos necesarios.
- **Access-Reject.** Enviado por el servidor RADIUS server en respuesta a un mensaje Access-Request. Este mensaje informa al cliente que su petición ha sido rechazada aportando la causa.
- **Access-Challenge.** Enviado por el servidor RADIUS server en respuesta a un mensaje Access-Request. Este mensaje se envía al cliente con un desafío que el cliente debe responder.
- **Accounting-Request.** Enviado por un cliente RADIUS para especificar la información de la conexión que le ha sido aceptada. Puede ser de tipo start o stop para iniciar o finalizar el accounting.
- **Accounting-Response.** Enviado por el servidor RADIUS server en respuesta a un mensaje Accounting-Request. Este mensaje notifica la recepción correcta de la solicitud e inicia el procesamiento de la sesión.



AUTHENTICATION

Autenticación

La Autenticación es el proceso por el que una entidad prueba su identidad ante otra. Normalmente la primera entidad es un cliente (usuario, ordenador, etc) y la segunda un servidor (ordenador). La Autenticación se consigue mediante la presentación de una propuesta de identidad (vg. un nombre de usuario) y la demostración de estar en posesión de las credenciales que permiten comprobarla. Ejemplos posibles de estas credenciales son las contraseñas, los testigos de un sólo uso (one-time tokens), los Certificados Digitales, ó los números de teléfono en la identificación de llamadas. Viene al caso mencionar que los protocolos de autenticación digital modernos permiten demostrar la posesión de las credenciales requeridas sin necesidad de transmitir las por la red

Authentication



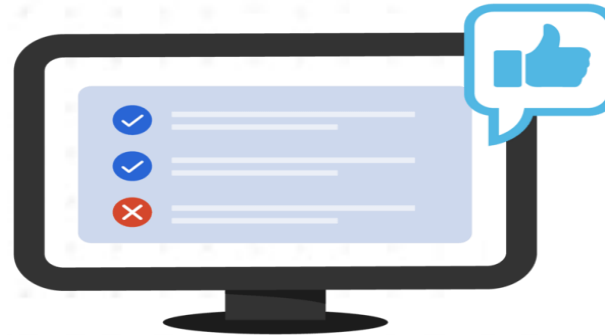
Confirms users are who they say they are.

AUTHORIZATION

Autorización

Autorización se refiere a la concesión de privilegios específicos (incluyendo "ninguno") a una entidad o usuario basándose en su identidad (autenticada), los privilegios que solicita, y el estado actual del sistema. Las autorizaciones pueden también estar basadas en restricciones, tales como restricciones horarias, sobre la localización de la entidad solicitante, la prohibición de realizar logins múltiples simultáneos del mismo usuario, etc. La mayor parte de las veces el privilegio concedido consiste en el uso de un determinado tipo de servicio. Ejemplos de tipos de servicio son, pero sin estar limitado a: filtrado de direcciones IP, asignación de direcciones, asignación de rutas, asignación de parámetros de Calidad de Servicio, asignación de Ancho de banda, y Cifrado.

Authorization



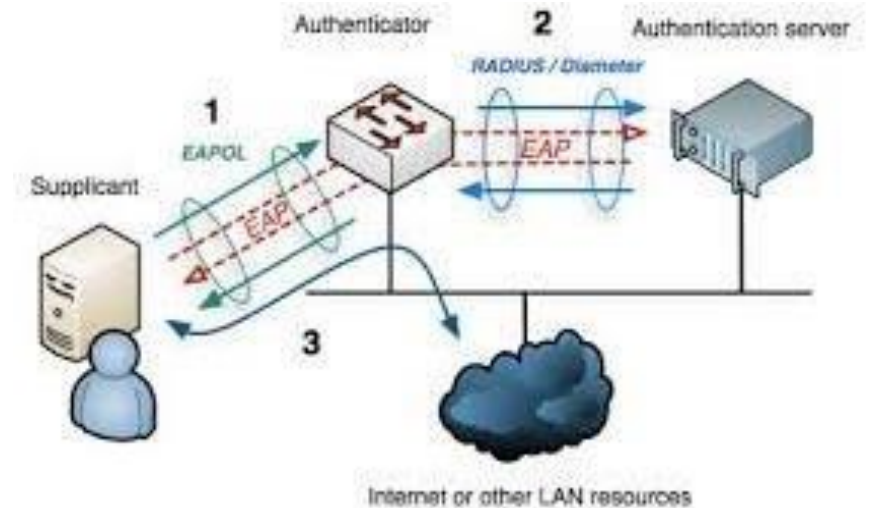
Gives users permission to access a resource.



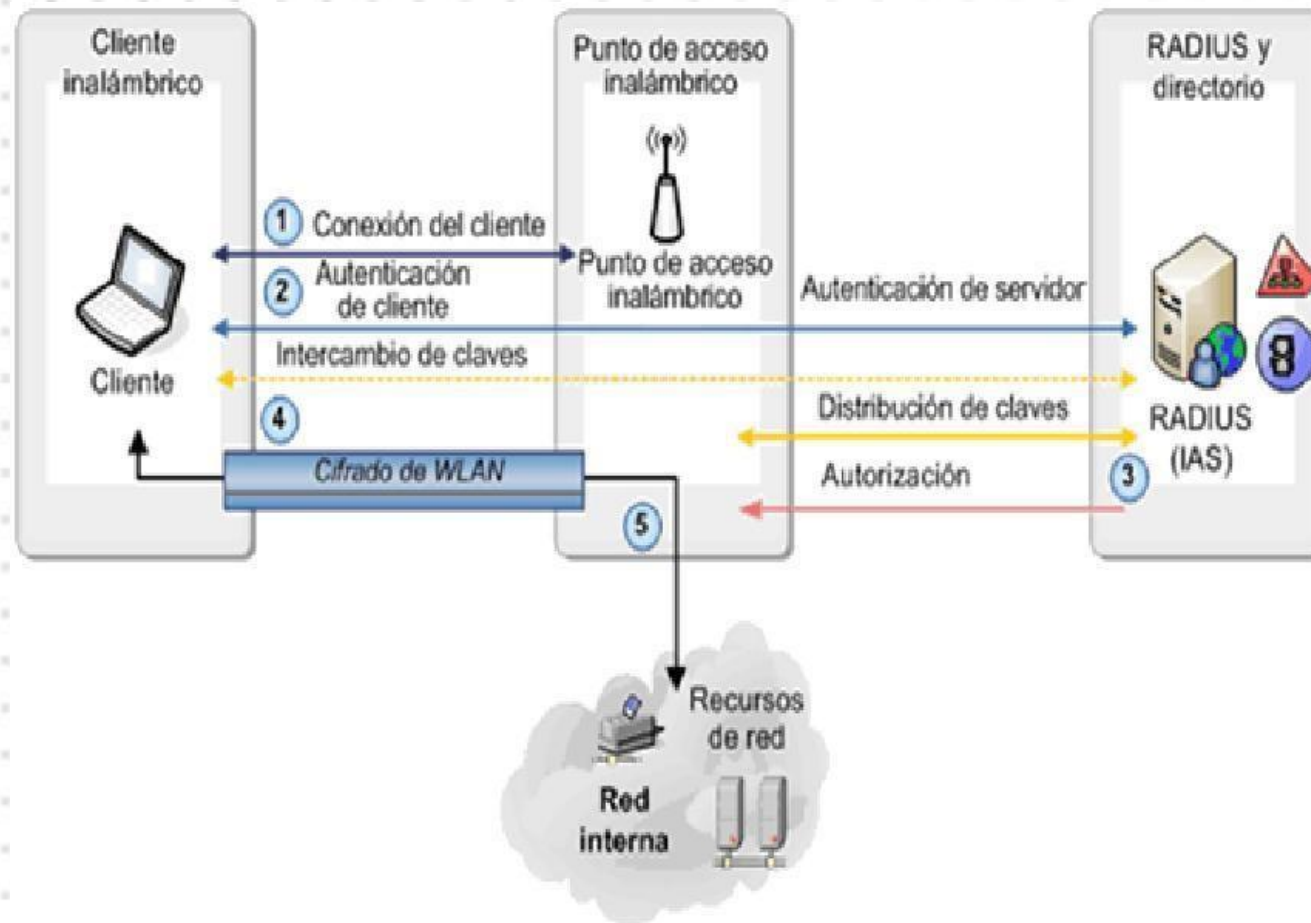
ACCOUNTING

Contabilización

La Contabilización se refiere al seguimiento del consumo de los recursos de red por los usuarios. Esta información puede usarse posteriormente para la administración, planificación, facturación, u otros propósitos. La contabilización en tiempo real es aquella en la que los datos generados se entregan al mismo tiempo que se produce el consumo de los recursos. En contraposición la contabilización por lotes (en inglés "batch accounting") consiste en la grabación de los datos de consumo para su entrega en algún momento posterior. La información típica que un proceso de contabilización registra es la identidad del usuario, el tipo de servicio que se le proporciona, cuando comenzó a usarlo, y cuando terminó.

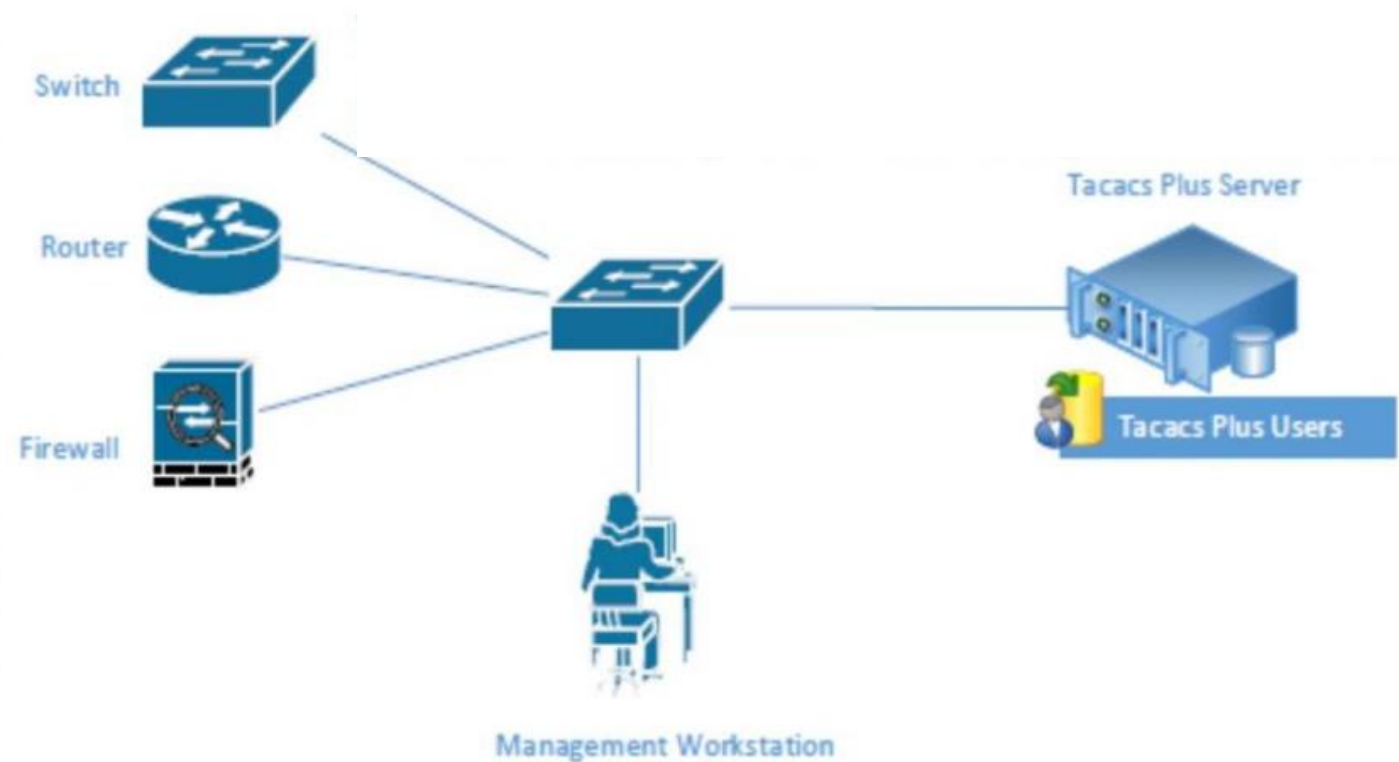


Secure Network Management



Protocolo TACACS +

TACACS + (Terminal Access Controller Access Control Server), es un protocolo de seguridad utilizado en el marco AAA para proporcionar autenticación centralizada para los usuarios que desean obtener acceso a la red.



Protocolo TACACS +

Características

1. Protocolo propietario de Cisco para el marco AAA, es decir, se puede utilizar entre el dispositivo Cisco y el servidor Cisco ACS.
2. Utiliza TCP como protocolo de transmisión.
3. Utiliza el puerto TCP número 49.
4. Si el dispositivo y el servidor ACS están usando TACACS +, entonces todos los paquetes AAA intercambiados entre ellos están encriptados.
5. Separa AAA en elementos distintos, es decir, la autenticación, la autorización y la contabilidad están separadas.
6. Proporciona un mayor control granular (que RADIUS) ya que se pueden especificar los comandos que están autorizados para ser utilizados por el usuario.
7. Proporciona soporte contable pero menos extenso que RADIUS.

Protocolo TACACS +

Funcionamiento

- ✓ El cliente de TACACS + se llama Dispositivo de acceso a la red (Nad) o Servidor de acceso a la red (NAS).
- ✓ El dispositivo de acceso a la red se comunicará con el servidor TACACS + para obtener un mensaje de nombre de usuario a través del mensaje **CONTINUAR** .
- ✓ Luego, el usuario ingresa un nombre de usuario y el dispositivo de acceso a la red se comunica nuevamente con el servidor TACACS + para obtener una solicitud de contraseña (mensaje Continuar) que muestra la solicitud de contraseña al usuario, el usuario ingresa una contraseña y luego la contraseña se envía al servidor TACACS +.

Protocolo TACACS +



Funcionamiento (cont.)

El servidor puede responder con uno de los siguientes mensajes de respuesta:

- Si las credenciales ingresadas son válidas, el servidor TACACS + responderá con un mensaje ACEPTAR.
- Si las credenciales ingresadas no son válidas, el servidor TACACS + responderá con un mensaje de RECHAZO.
- Si el enlace entre el servidor TACACS + y el servidor NAS o TACACS + no funciona correctamente, responderá con un mensaje de ERROR.
- Si se requiere autorización TACACS +, se contacta de nuevo con el servidor TACACS + y éste devuelve una respuesta de autorización ACEPTAR o RECHAZAR. Si se devuelve el mensaje ACEPTAR, contiene atributos que se utilizan para determinar los servicios que un usuario puede realizar.

Para la contabilidad, el cliente enviará un mensaje de SOLICITUD al servidor TACACS + para el cual el servidor responde con un mensaje de RESPUESTA indicando que se recibió el registro.

Protocolo TACACS +

Ventajas

1. Proporciona un mayor control granular que RADIUS. TACACS + permite que un administrador de red defina qué comandos puede ejecutar un usuario.
2. Todos los paquetes AAA están encriptados en lugar de contraseñas (en el caso de Radius).
3. TACACS + usa TCP en lugar de UDP. TCP garantiza la comunicación entre el cliente y el servidor.

Desventajas

1. Como es propiedad de Cisco, solo se puede utilizar entre los dispositivos de Cisco.
2. Soporte para contabilidad menos extenso que RADIUS.

Protocolo Kerberos



- ❑ Kerberos es un **servicio de autenticación** utilizado en redes informáticas abiertas o no seguras.
- ❑ Este protocolo de seguridad sirve para autenticar las solicitudes de servicio entre dos o más hosts de confianza a través de una red no fiable, como Internet.
- ❑ El cifrado criptográfico y un **tercero** (también llamado trust third party) de confianza se utilizan para autenticar las aplicaciones cliente-servidor y verificar la identidad de los usuarios.
- ❑ Actualmente, Kerberos es la tecnología de autorización estándar de Microsoft Windows. Sin embargo, Kerberos tiene también implementaciones para otros sistemas operativos, como Apple OS, FreeBSD, UNIX y Linux.
- ❑ Microsoft lanzó su versión del protocolo Kerberos en Windows 2000. Después, pasó a convertirse en el protocolo estándar para páginas web e implementaciones de inicio de sesión único en varias plataformas.

Protocolo Kerberos

Proceso de Autenticación

Paso 1. El cliente realiza una solicitud cifrada al servidor de autenticación. Cuando el AS recibe la solicitud, busca la contraseña en la base de datos de Kerberos mediante el ID de usuario. Si la contraseña de usuario es correcta, el AS descifra la solicitud.

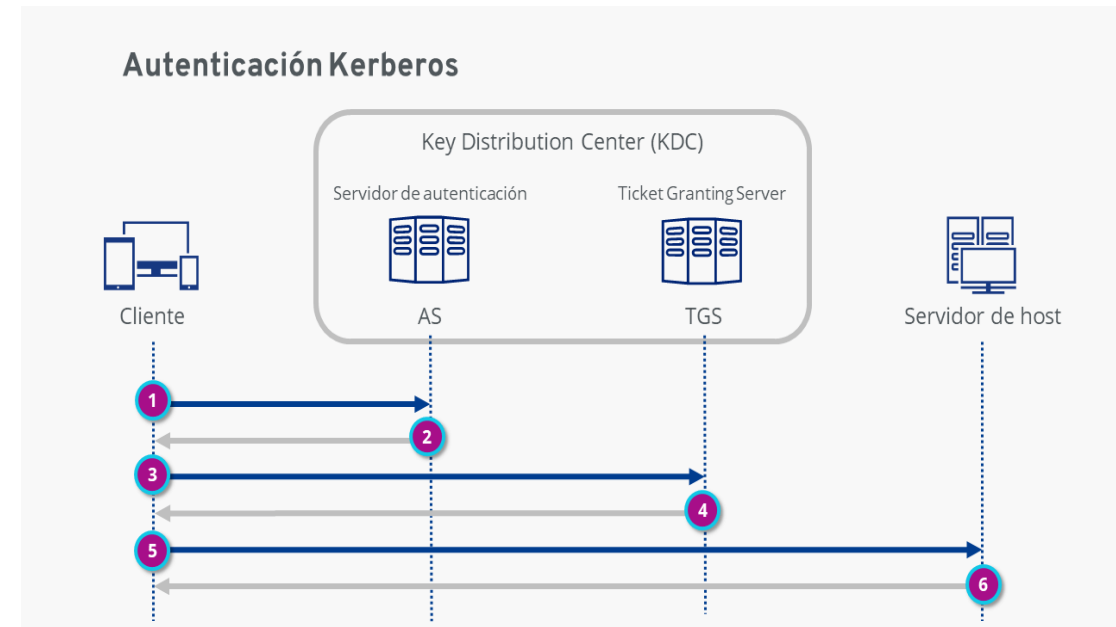
Paso 2. Una vez se verifica el usuario, el AS emite un ticket-granting ticket (TGT), que se envía de vuelta al cliente.

Paso 3. El cliente envía el TGT al ticket-granting server. Junto con el TGT, el cliente indica también el motivo de acceso al servidor de host. El TGS descifra el ticket con la clave secreta que comparten el AS y el TGS.

Paso 4. Si el TGT es válido, el TGS emite un ticket de servicio para el cliente.

Paso 5. El cliente envía el ticket de servicio al servidor de host. El servidor descifra el ticket con la clave secreta que comparten el servidor y el TGS.

Paso 6. Si las claves secretas coinciden, el servidor de host permite al cliente acceder al servicio. El ticket de servicio determina el tiempo que el usuario puede utilizar el servicio. Una vez caduca el acceso, este se puede renovar repitiendo de nuevo todo el protocolo de autenticación de Kerberos.



Protocolo Kerberos



❑ Ventajas

- ✓ La autorización por parte de terceros lo convierte en uno de los **protocolos de verificación más seguros del mundo digital**. Además, las contraseñas nunca se envían por la red en texto simple. Las “claves secretas” solo se transmiten por el sistema de forma cifrada. Kerberos permite también hacer un mejor seguimiento de quién solicitó qué y en qué momento.
- ✓ Kerberos permite a los usuarios y los proveedores de servicios **realizar una autenticación mutua**. En cada paso del proceso de autenticación, tanto los usuarios como los sistemas de servidores saben que su interlocutor es auténtico.

❑ Desventajas

- ✓ Si el servidor de Kerberos no funciona, los usuarios no pueden conectarse.
- ✓ Existen estrictos requisitos de tiempo: las configuraciones de fecha y hora de los hosts implicados deben estar siempre sincronizadas dentro de unos límites preestablecidos. Fuera de estos periodos, las autenticaciones dan error, porque los tickets solo están disponibles por tiempo limitado.
- ✓ Algunos **sistemas antiguos** no son compatibles con los mecanismos de autenticación de terceros.
- ✓ A pesar de que las contraseñas de la autenticación Kerberos suelen ser seguras, los hackers pueden obtenerlas mediante ataques de fuerza bruta o robarlas a través de phishing. Este es uno de los motivos por los que la autenticación multifactor (MFA) es un medio cada vez más popular para proteger las identidades en línea.

Conclusiones

- Aplicar los protocolos AAA permite el acceso de los usuarios legítimos a los activos conectados a la red e impide el acceso no autorizado, esto ayuda a las organizaciones a mantener la seguridad en sus activos y evitará posibles ataques o accesos no autorizados.

Actividad en Canvas

- ❑ Desarrollar un cuadro comparativo de las características de los protocolos Radius, Kerberos y Tacacs +.



Universidad
Tecnológica
del Perú



Universidad
Tecnológica
del Perú

Gracias!

Desaprende lo que te limita



**Universidad
Tecnológica
del Perú**